

Управление правами доступа в Linux

Discretionary access control (DAC)

Дискреционный механизм реализуется в виде прав доступа для файлов (объектов) ОС

```
whoaim  
id
```

владелец группа остальные

```
uid=1000(simple) gid=1000(simple) groups=1000(simple),10(wheel)  
context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
```

```
-rw-----: Файл, который доступен только его владельцем.  
-rwxr-xr-x: Файл, который является исполняемым любым пользователем в системе.  
-rw-rw-rw-: Файл, который открыт для модификации каждого пользователя в системе.  
drwxr-xr-x: каталог, что каждый пользователь в системе может читать и доступ.  
drwxrwx ---: Каталог, который является изменяемым (включая его содержание) его  
владельцем и группой.  
drwxr-x ---: Каталог, который доступен по своей группе.
```

t-bit - разрешает удаление файла из каталога только владельцу файла

```
0 --- ---  
1 --x 001  
2 -w- 010  
3 -wx -11  
4 r-- 100  
5 r-x 101  
6 rw- 110  
7 rwx 111
```

setuid set user ID upon execution - установка ID пользователя во время выполнения (разрешают пользователям запускать исполняемые файлы с правами владельца исполняемого файла.)

Процесс будет иметь те же права что и владелец файла.

Например: команда passwd имеет SUID bit. Когда обычный пользователь захочет изменит свой пароль в файле /etc/passwd или /etc/shadow, то у него ничего не получится, т.к нужны права суперпользователя (процесс командны PASSWD всегда работает с правами суперюзера).

```
find / -perm -4000 -o -perm -2000 -print - Найти все SUID и SGID файлы
```

ACL

```
getfacl test
setfacl -m u:dummy:r /tmp/test_acl
setfacl -x u:iivanov secretfile - удалить права
setfacl -R -x u:apetrov folder удалить рекурсивно все права в директории
```

SELINUX

SELINUX - система обеспечивающая мандатную модель контроля доступа.

Мандатное управление доступом (англ. Mandatory access control, MAC) — разграничение доступа субъектов к объектам, основанное на назначении метки конфиденциальности для информации, содержащейся в объектах, и выдаче официальных разрешений (допуска) субъектам на обращение к информации такого уровня конфиденциальности.

SELINUX активируется после классической системы контроля доступа.

Субъект - процесс, объект - файл или системный вызов. Взаимодействие субъекта и объекта помечается специальной меткой - контекст безопасности. Метки хранятся в расширенных атрибутах FS.

Терминалогия SELINUX Policy - коллекция правил, которые определяют какой источник (субъект) должен иметь права к цели (объект).

Source domain - объект пытающийся получить доступ к цели. Обычно это процесс или пользователь.

Target domain - объект к которому пытаются получить доступ. Обычно файл или порт.

Context - Метка безопасности, которая используется для категоризации объекта

Rule - Специальная часть политики, которая определяет, какой источник имеет права к target domain

Состояние SELINUX

enforcing - SELINUX блокирует неразрешенную активность

permissive - SELINUX только логирует активность, но не блокирует

disabled - выключено

Посмотреть настройки

`cat /etc/sysconfig/selinux` Посмотреть детальную информацию

`sestatus -v`

`setenforce 0` - выключить SELINUX

Чтобы посмотреть context label:

```
ps -eZ [| grep имя_программы] - посмотреть контекст запущенного процесса
ls -Z : контекст SELinux для файлов.
id -Z : контекст SELinux для текущего пользователя.
```

Каждая метка содержит три части

TODO

USER - пользователь в SELINUX это не тоже самое, что Linux users (например alluser это unconfined_u).

По умолчанию пользователей мало, только system_u и unconfined_u

Role - тоже самое с ролями unconfined_r и system_r

Type - context type

Установить context type можно двумя утилитами:

semanage и chcon, рекомендуется использовать первую

если semanage не установлен, нужно найти rpm - yum whatprovides */semanage

Пример как установить context type на все директории каталога рекурсивно

```
semanage fcontext -a -t httpd_sys_content_t "/mydir(/.*)?"
```

Затем необходимо применить эти настройки из политики:

```
restorecon -R -v /mydir
```

Просмотреть мета правила - это низкоуровневые правила для настройки разрешения приложений:

```
semanage boolean -l  
или  
getsebool -a
```

Можно выключить полностью блокировку на контекст:

```
semanage permissive -a httpd_t
```

Пример активации такой настройки:

```
setsebool ftpd_anon_write on
```

Чтобы применить setsebool -P

Просмотреть лог SELINUX

```
grep AVC /var/log/audit/audit.log
```

Найти все файлы с нужным контекстом

```
find /etc -context '*net_conf_t'
```

Восстановить правильный контекст

```
restorecon -v /usr/sbin/httpd
```

avc: denies {тип запроса}- говорит о том, какой тип запроса был отклонен

sealert -b - графическая утилита для просмотра логов. Если иксов нет, то можно сгенерировать отчет удобнее

```
sealert -a /var/log/audit/audit.log > /path/to/mylogfile.txt
```

audit2allow - для создания пользовательских политик

Также SELINUX контролирует доступ к портам

Посмотреть полный список портов, к которым SELINUX по умолчанию предоставляет доступ:

```
semanage port -l
```

Установить контекст:

```
semanage port -a -t http_port_t -p tcp 81
```